

Security+ 4.6 · Access Controls

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.6 — Access Controls (7:49)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Modelos: ACL (por recurso, lista); MAC (obrigatório por CLASSIFICAÇÃO — militar, SELinux); DAC (discretionary — o DONO do arquivo decide, Windows FS); RBAC (por FUNÇÃO); ABAC (atributos); time-of-day restriction.

Highlights que a prova cobra

- MAC: o sistema decide por classificação (militar/SELinux)
- DAC: o DONO decide (Windows file permission)
- RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico

Dicas de prova & Cenários Típicos

- 'permissions determined by data classification'=MAC

Cenário clássico de exame: 'arquivo só acessado por usuários com clearance alto'=MAC.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.6 — Access Controls)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **RBAC:** Role-Based Access Control: Modelo de controle de acesso onde as permissões são atribuídas a funções/papéis do cargo (roles), e não aos indivíduos diretamente.
- **ABAC:** Attribute-Based Access Control: Modelo de controle de acesso mais dinâmico que avalia atributos do usuário, do recurso, da ação e do ambiente (horário, localização, dispositivo).
- **MAC:** Mandatory Access Control: Modelo rígido de controle de acesso governamental/militar baseado em etiquetas de segurança (Top Secret, Secret, Unclassified) atribuídas por autoridade central.
- **DAC:** Discretionary Access Control: Modelo onde o proprietário (criador) do arquivo decide livremente quem tem permissão de leitura, gravação ou execução.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:

- A)** Menor privilégio
- B)** Separação de funções
- C)** Rotação de cargo
- D)** Need-to-know geográfico

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'MAC: o sistema decide por classificação (militar/SELinux)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'DAC: o DONO decide (Windows file permission)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "permissions determined by data classification'=MAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'permissions determined by data classification'=MAC...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "arquivo só acessado por usuários com clearance alto'=MAC.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'arquivo só acessado por usuários com clearance alto'=MAC....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'MAC: o sistema decide por classificação (militar/SELinux)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'DAC: o DONO decide (Windows file permission)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Menor privilégio.

✓ **Por que está certa:** A alternativa correta é 'Menor privilégio'. O princípio do menor privilégio (least privilege) determina que cada usuário, processo ou sistema deve receber apenas as permissões estritamente necessárias para executar suas funções, e nada além disso. No contexto de segurança da informação, isso reduz a superfície de ataque e limita o impacto de um comprometimento. Por exemplo, um usuário do departamento financeiro não deve ter acesso a arquivos de recursos humanos. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.1), lista o menor privilégio como um princípio fundamental de segurança. A questão descreve exatamente essa definição: dar a cada usuário só o acesso mínimo que ele precisa para a função.

✗ **Por que as outras estão erradas:**

- *Separação de funções:* Separação de funções (separation of duties) é um controle que divide uma tarefa crítica em etapas executadas por pessoas diferentes, de modo que nenhuma pessoa tenha controle total sobre o processo. Por exemplo, quem aprova um pagamento não pode ser o mesmo que o executa. Isso evita fraudes e erros, mas não se refere a conceder o mínimo de acesso por usuário; em vez disso, distribui responsabilidades. A questão fala de acesso mínimo individual, não de divisão de tarefas.
- *Rotação de cargo:* Rotação de cargo (job rotation) é uma prática de mover funcionários periodicamente entre diferentes funções para detectar fraudes, reduzir monotonia e treinar pessoal. Não tem relação com o princípio de conceder apenas o acesso necessário. Rotação de cargo é uma estratégia de mitigação de riscos internos, mas não define o nível de privilégio de cada usuário.
- *Need-to-know geográfico:* Need-to-know é um princípio de segurança que restringe o acesso à informação apenas a quem precisa dela para realizar uma tarefa específica. No entanto, 'need-to-know geográfico' não é um termo padrão na certificação CompTIA Security+. O conceito de need-to-know é frequentemente associado ao menor privilégio, mas a expressão 'geográfico' adiciona uma restrição de localização que não está presente na definição clássica. A questão não menciona restrição geográfica, apenas acesso mínimo funcional. Portanto, a alternativa é imprecisa e não corresponde ao termo técnico correto.

2) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar:* Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e

'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.

- *Planejar, Fazer, Checar, Agir, Revisar*: Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.
- *Prevenir, Punir, Prever, Provar, Publicar*: Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

3) B — Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): MAC: o sistema decide por classificação (militar/SELinux).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): DAC: o DONO decide (Windows file permission).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'permissions determined by data classification'=MAC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): 'permissions determined by data classification'=MAC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'arquivo só acessado por usuários com clearance alto'=MAC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): 'arquivo só acessado por usuários com clearance alto'=MAC..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): MAC: o sistema decide por classificação (militar/SELinux).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): DAC: o DONO decide (Windows file permission).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

